

Fundamentals of Computer Security

BCS2420

Dr. Ashish Sai

ashish.sai@maastrichtuniversity.nl

THE NETHERLANDS

CLASSES CANCELLED AT EINDHOVEN UNIVERSITY OF TECHNOLOGY

10

Matrix
Groene Loper

Entrance →

Entrance ↗

Entrance

TU/e

TU/e Innovation Space
Equipment & Prototype Center

Slower Internet at UU and other institutions

Another cyber attack against higher education contained



Once again, higher education institutions in the Netherlands were hit by a distributed denial-of-service (DDoS) attack. All universities and universities of applied sciences struggled with a slower Internet, reports SURF, the ICT cooperative of Dutch education and research institutions. The attack has since been contained.

CRIME | NETHERLANDS

Dutch university wins big after Bitcoin ransom returned

07/02/2022

Maastricht University has doubled its money thanks to a ransomware attack three years ago. The university plans to help struggling students with its new funds.



After a ransomware attack in 2019, Maastricht University will get half a million euros back

Image: Gudrun Petersen/Joker/picture alliance

The Problem: 50 years ago, no internet transactions.

Today, billions are transferred online daily!  Cybercrime cost **\$6T** in 2021.

The image shows the World Economic Forum logo, which consists of the words "WORLD ECONOMIC FORUM" in a bold, sans-serif font, arranged in three lines. A thin, dark circular line is drawn around the text. The logo is on a glass surface, and the background is a blurred view of a mountain range under a clear blue sky. A wooden beam is visible in the upper right corner.

WORLD
ECONOMIC
FORUM

If annual **cybercrime** were a country, it would have the **third-largest gross domestic product (GDP) worldwide.**

WannaCry Ransomware Attack

- **Date:** May 2017
- **Incident:** Ransomware exploiting Windows vulnerabilities, encrypting data and demanding Bitcoin payments.
- **Impact:** Affected over **230,000 computers** in 150+ countries, including the **UK's NHS**.





NotPetya Malware Attack

- **Date:** June 2017
- **Incident:** Malware disguised as **ransomware**, targeting Ukrainian 🇺🇦 infrastructure and spreading globally 🌐.
- **Impact:** Disrupted operations of major corporations like Maersk and Merck, with damages over **\$10 billion**.

Stuxnet Worm

- **Date:** Discovered in 2010
- **Incident:** Sophisticated worm targeting *Siemens PLCs*, aimed at Iran's 🇮🇷 nuclear facilities.
- **Impact:** *Damaged centrifuges* at Iran's Natanz facility, delaying nuclear progress.





TRITON Malware Attack on Saudi Petrochemical Plant

- **Date:** August 2017
- **Incident:** TRITON malware targeted the **safety systems** of a Saudi **petrochemical** plant, aiming to **disable** safety mechanisms and cause **physical damage**.
- **Impact:** Detected and halted before causing harm, marking a significant escalation in cyber threats to critical infrastructure.

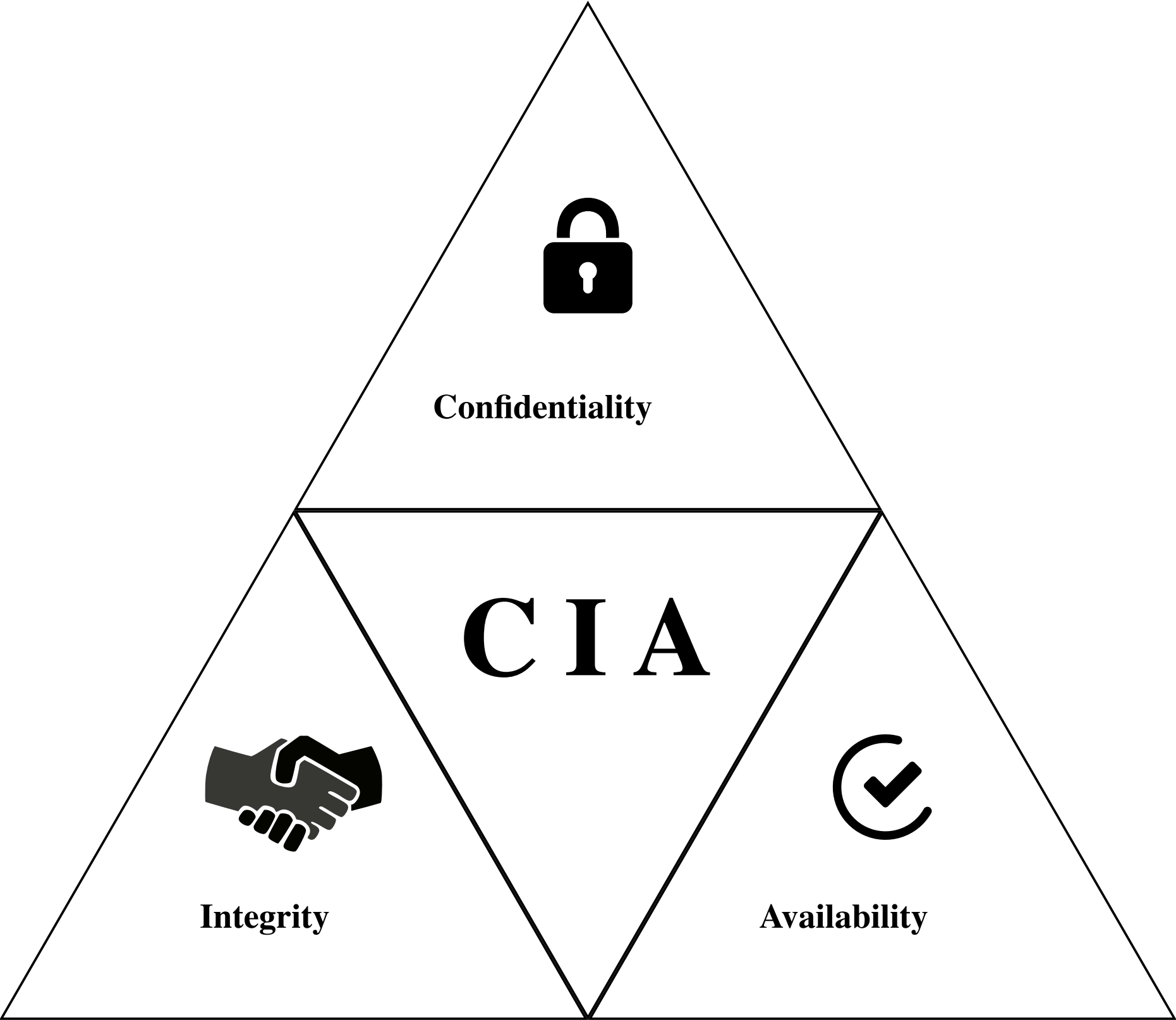
Security Concepts and Principles

Computer Security and Internet Security

- Security of software, computers, and computer networks.
- Protecting information transmitted over and stored on *these devices*.
- Includes PCs, laptops, tablets, smartphones, servers, and network devices (firewalls, routers, switches).

Computer security is the combined *art, science, and engineering* practice of protecting computer-related assets from unauthorized actions and their consequences, either by **preventing** such actions or **detecting** and **recovering** from them.

Fundamental Goals of Computer Security



Confidentiality

Definition

- Non-public information remains accessible **only** to authorized parties.
- Supported by access control , encryption , and procedural means .

Confidentiality

Methods

- **Access Control:** Enforced by the operating system.
- **Data Encryption:** Cryptographic algorithms ¹.
- **Procedural Means:** Physical access restrictions to offline storage media.

1. More on this in Lecture 2. ↩

Integrity

Definition

- Ensures **data**, **software**, or **hardware** remains **unaltered**, except by *authorized parties*.

Integrity

Methods

- **Error Detection/Correction Codes:** Handle benign errors.
- **Access Controls and Cryptographic Checksums:** Combat malicious integrity violations.

Example: Ensuring software updates are not tampered with.

Availability

Definition

- Ensures information, services, and computing resources are accessible for **authorized** use.

Availability

Methods

- **Reliable Hardware and Software:** Ensure system reliability.
- **Protection Mechanisms:** Prevent intentional disruptions such as denial of service attacks.

Authorization

Definition

- Computing resources accessible only by authorized entities.

Authorization

Methods

- **Access Control Mechanisms:** Restrict access to physical devices, software services, and information.

Authentication

Definition

- Assurance that a **principal**, **data**, or **software** is **genuine**.

Authentication

Types

- **Entity Authentication:** Verifies the **identity of users**.
- **Data Origin Authentication:** Verifies the **source of data**.

Accountability

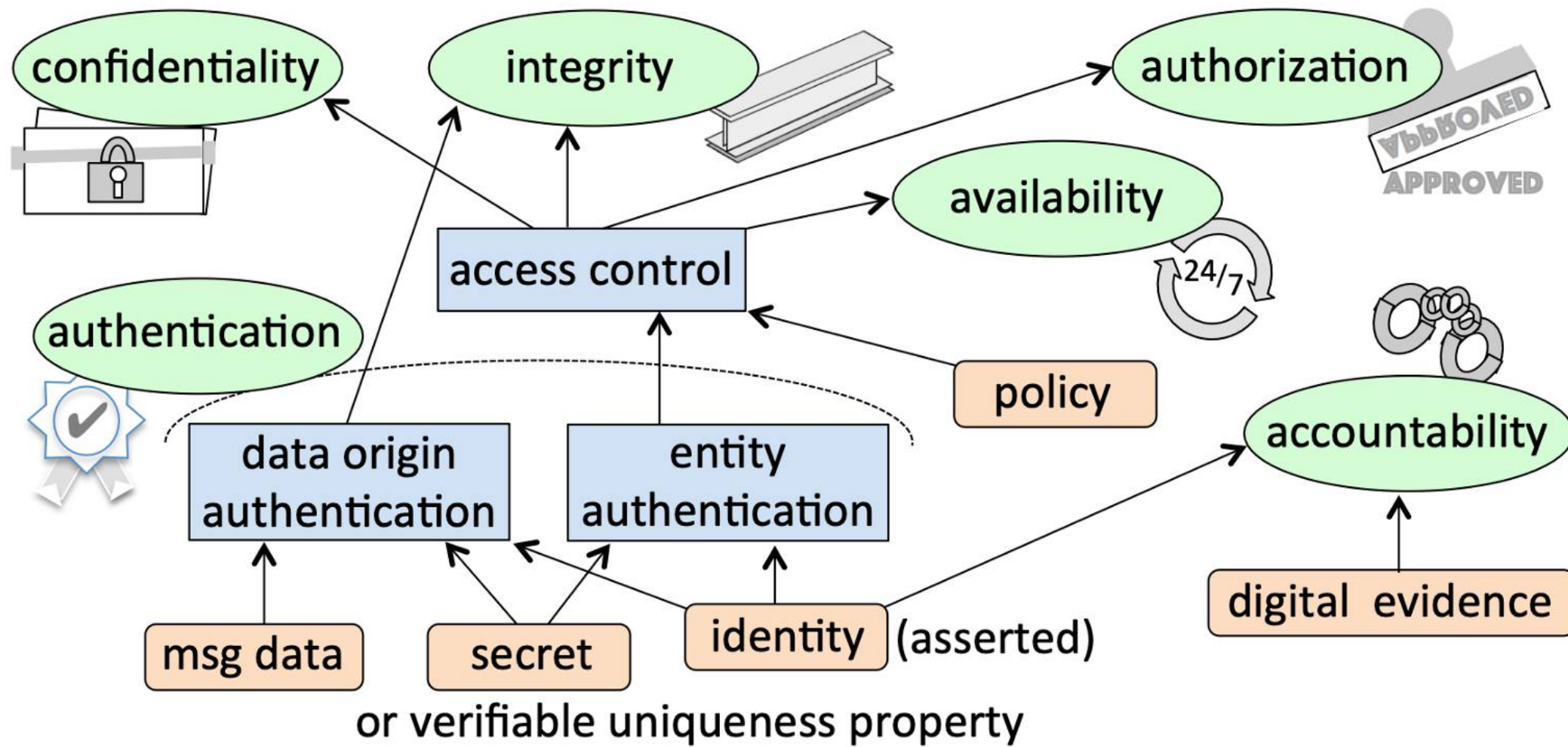
Definition

- Ability to identify principals **responsible** for actions.

Accountability

Methods

- **Transaction Evidence and Logs:** Electronic means to record actions and identify principals.



Key Terms

Computer Security

Security Policy

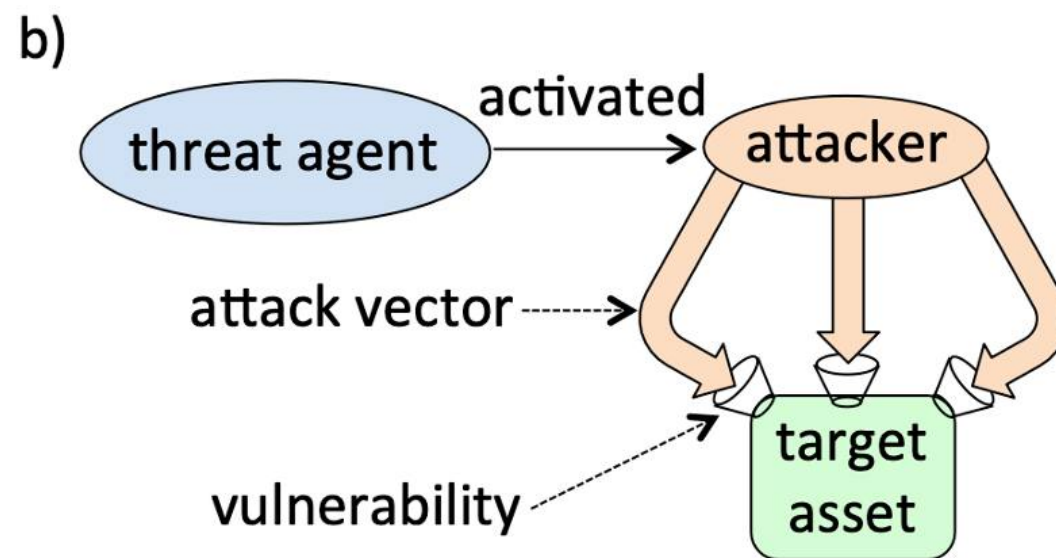
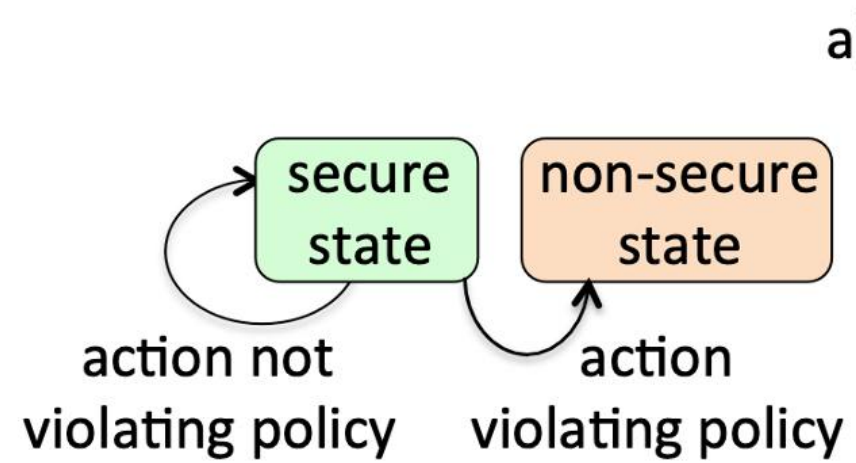
- Specifies system rules and practices, defining what is **allowed** and **not allowed**.

Attacks

- Deliberate steps intended to cause a security violation.

Examples:

- Unauthorized Access
- Data Breaches
- Denial of Service (DoS) Attacks



Risk Assessment and Modeling

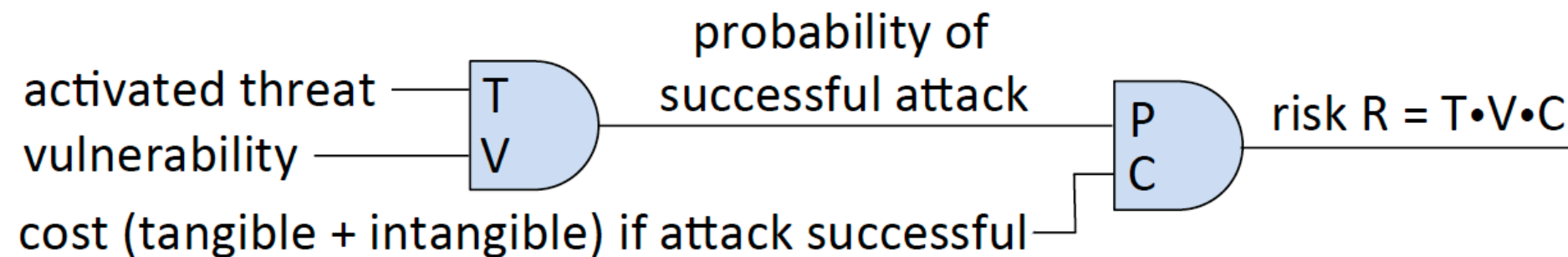
Risk

- Risk is the **expected loss** due to **harmful** future events *relative to* **assets** and over a fixed time period.

Risk Equation

$$R = T \times V \times C$$

- **T (Threat):** Probability of threat occurrence.
- **V (Vulnerability):** Presence of system vulnerabilities.
- **C (Cost):** Impact cost of a successful attack.



Adversary Modeling

Adversary Modeling

Definition

- Identifying and understanding potential attackers, their objectives, methods, capabilities, and resources.

Attributes of Adversary

1. **Objectives:** Goals of the adversary.
2. **Methods:** Attack techniques used.
3. **Capabilities:** Resources, skills, and knowledge available.
4. **Funding Level:** Financial resources influencing determination and methods.
5. **Outsider vs. Insider:** Origin of the attack.

Adversary Attributes

1- Objectives:

- These often suggest target assets requiring special protection.
- *Examples:* Stealing sensitive data, disrupting services, financial gain.

Adversary Attributes

2- Methods:

- Anticipated attack techniques or types of attacks.
 - *Examples:* Phishing, malware, social engineering, direct network attacks.

Adversary Attributes

3- Capabilities:

- Computing resources (CPU, storage, bandwidth), skills, knowledge, personnel, opportunity (e.g., physical access to target machines).
- *Examples:* Access to high-powered computers, knowledge of system vulnerabilities, skilled personnel.

Adversary Attributes

4- Funding Level:

- Influences attacker determination, methods, and capabilities.
- *Examples:* Government-funded agencies vs. individual hackers.

Adversary Attributes

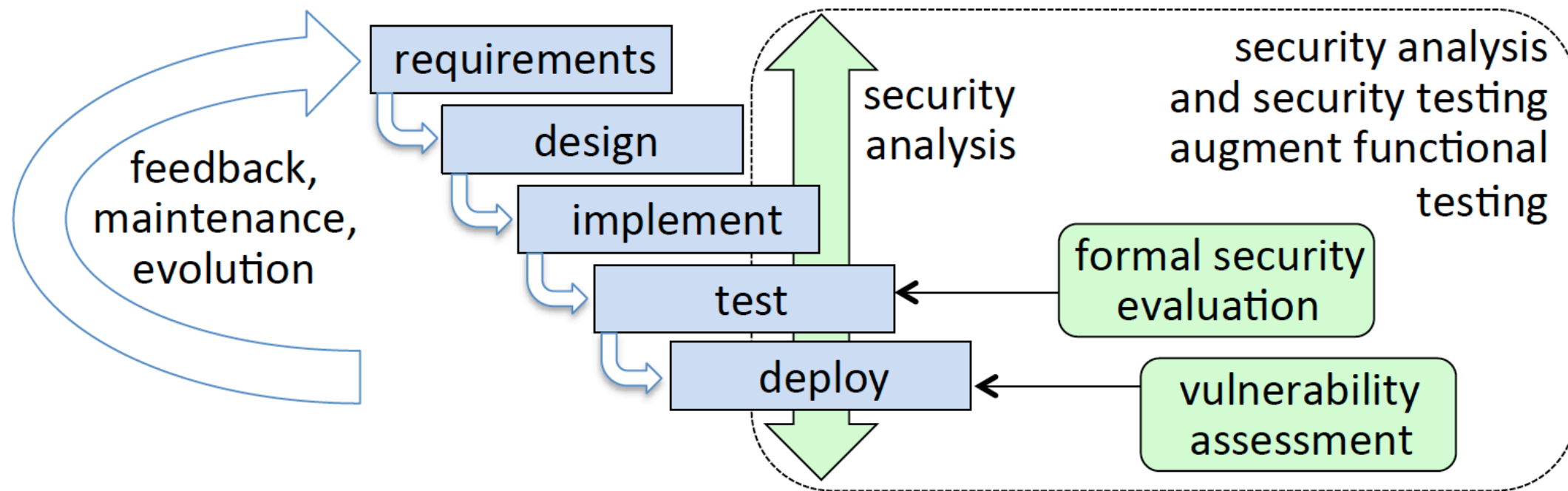
5- Outsider vs. Insider:

- Outsiders launch attacks without prior special access.
- Insiders have some starting advantage, such as employees with network credentials.

Named Groups of Adversaries

- 1 Foreign intelligence (including government-funded agencies)
 - 2 Cyber-terrorists or politically-motivated adversaries
 - 3 Industrial espionage agents (perhaps funded by competitors)
 - 4 Organized crime (groups)
 - 5 Lesser criminals and crackers (i.e., individuals who break into computers)
 - 6 Malicious insiders (including disgruntled employees)
 - 7 Non-malicious employees (often security-unaware)
-

Security and Software



Threat Modelling Approaches

Threat Modelling

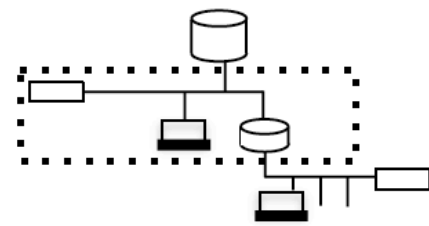
Threat Model

- Identifies threats, threat agents, and attack vectors considered in scope to defend against.

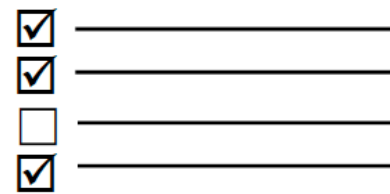
Threat Modelling

Approaches:

1. Diagram-Driven Threat Modeling
2. Attack Trees
3. Checklists
4. STRIDE



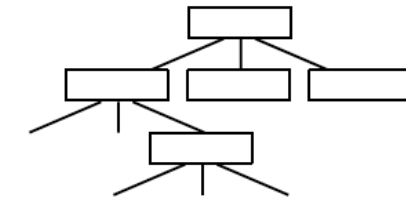
architectural
diagrams



checklists

threat
model

attack trees



STRIDE

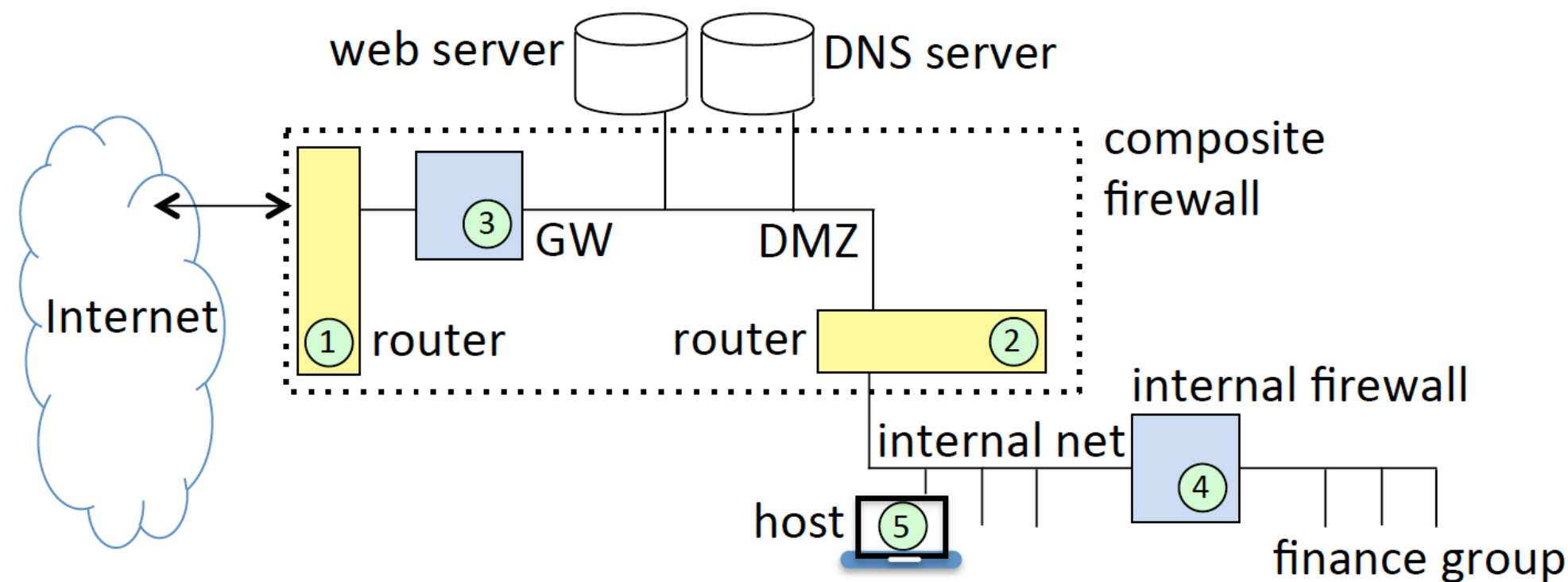
Spoofing
Tampering
Repudiation
Information disclosure
Denial of service
Escalation of privilege

Diagram-Driven Threat Modeling

- A visual approach starting with an architectural representation of the system.
- Diagrams show system components and data flow links, identifying gateways and trust domains¹.

1. Areas with shared security policies or trust levels ↩

Diagram-Driven Threat Modeling Steps¹



1. Firewall: A security system that monitors and controls network traffic based on predefined rules. ↩

1. Draw an **architectural diagram** with **system components and communication links**.
2. Mark **gateways** where controls **restrict** communication.
3. Define **trust domains** based on **trust** assumptions (e.g., authenticated users).
4. Assess how trust assumptions could be **violated** for each component, link, and domain.
5. Simplify into a **data flow diagram** tracing data flow through tasks.
6. --

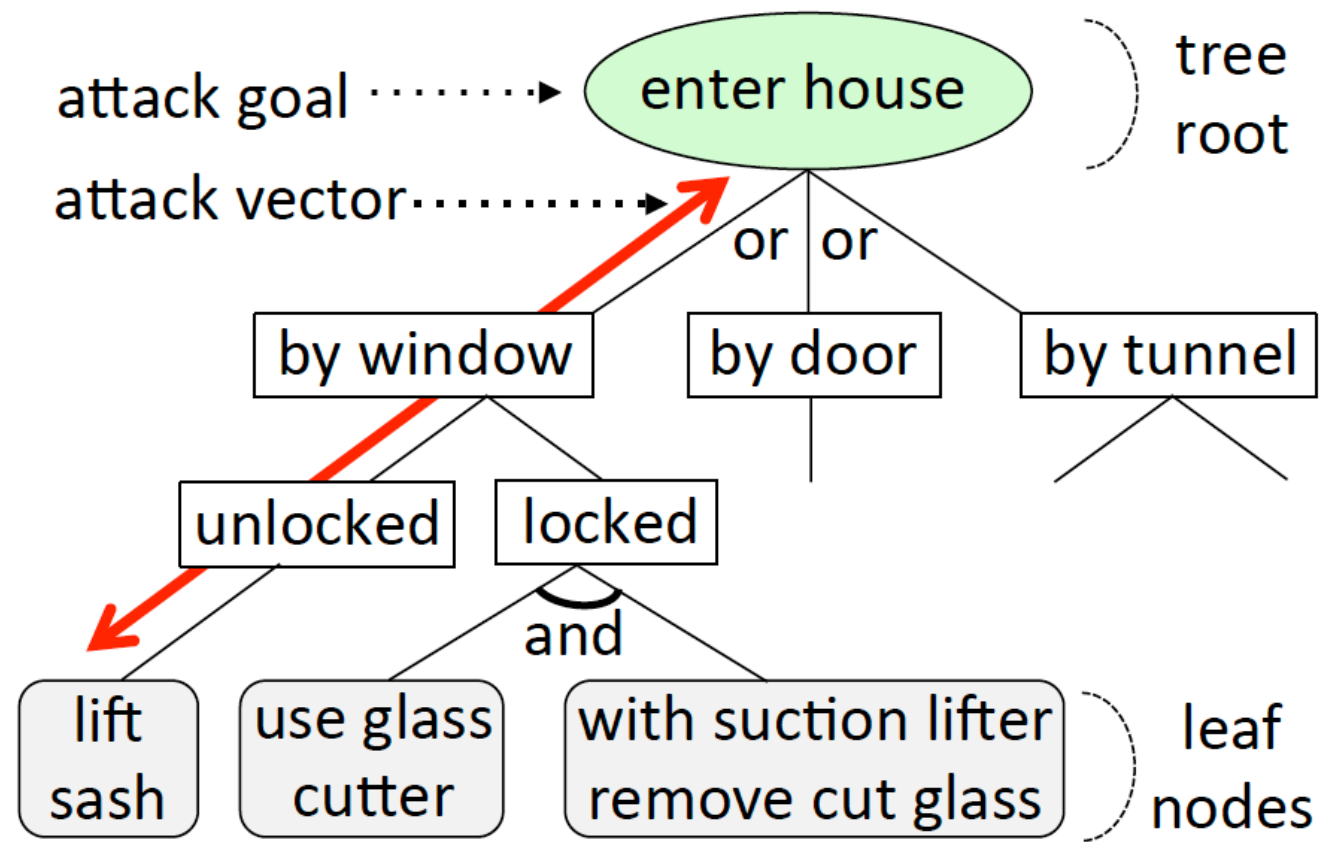


Consider User Workflow

- **Trace user actions** from task **initiation to completion**, including *uncommon tasks like account creation and software updates*.
- Highlight where sensitive data is stored and ensure all access paths are shown.

Attack Trees for Threat Modeling

- Attack trees identify **attack vectors** using a hierarchical model starting with an **overall attack goal**.



Attack Trees for Threat Modeling Steps

1. Label the root node with the attack goal (e.g., enter a house).
2. **Decompose** into lower nodes with alternative methods (e.g., window, door, tunnel).
3. Further refine each method into **specific actions** (e.g., unlock, break).
4. Each path from **leaf to root** represents an attack vector.

Checklists

- Fixed attack checklists drawn from past experiences to ensure well-known threats are not overlooked.

STRIDE

- A mnemonic for recalling six categories of threats.
Where can things break? Maybe STRIDE

Categories:

1. **Spoofing:** Impersonating entities (e.g., websites, users).
2. **Tampering:** Unauthorized alteration of code, data, or packets.
3. **Repudiation:** Denying responsibility for actions.
4. **Information Disclosure:** Unauthorized release of data.
5. **Denial of Service:** Disrupting service availability.
6. **Escalation of Privilege:** Gaining unauthorized access levels.

Model-Reality Gaps and Real-World Outcomes

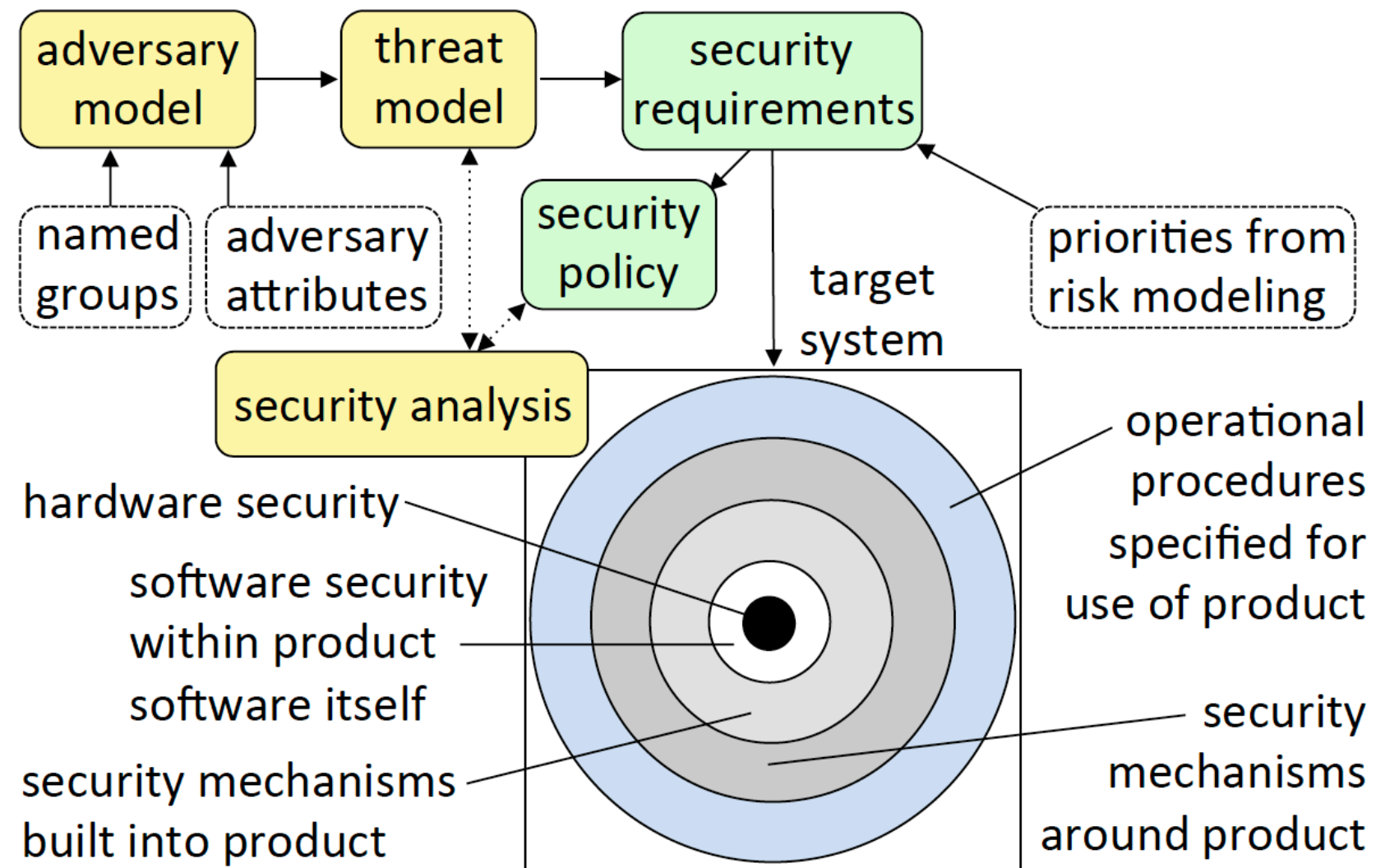
Threat modeling is **difficult** due to *invalid assumptions* and focusing on **wrong threats**.

Example (Hotel Safebox)

- Checking into a hotel with a small safe, the combination **chosen** by the guest might **not** be secure against hotel staff with **master keys**.

Quality of a Threat Model

- Depends on how accurately it reflects system details and operating environment.
- Gaps arise from **abstraction**, **invalid assumptions**, and **misplaced** trust.



Why Computer Security is Hard

- Rapid technological changes.
- Evolving attack techniques.
- Human factors and usability issues.

Security is an ongoing process requiring constant vigilance and adaptation.

Course Logistics

Computer Security

This course offers a comprehensive introduction to computer security, focusing on:

- Cryptography
- Software, network, and web security

Course Objectives

By the end of the course, students will be able to:

1. Grasp foundational security concepts and principles.
2. Understand cryptographic building blocks for secure communication.
3. Implement secure user authentication mechanisms.
4. Analyze authentication and key establishment protocols.
5. Recognize and counteract malicious software threats.
6. Enhance web and browser security using best practices.
7. Deploy firewalls and establish secure tunnels for data transmission.
8. Detect intrusions and mitigate network-based attacks.
9. Secure wireless LANs (e.g., Wi-Fi) and evaluate 802.11 standards.
10. Understand blockchain technologies (e.g., Bitcoin, Ethereum).



Lecture Schedule

Week	Lecture 1	Lecture 2
Week 1	Fundamentals of Computer Security	Foundations of Cryptography
Week 2	Authentication Methods	Protocols for Secure Communication
Week 3	Malware Threats	Securing Web Applications
Week 4	Network Defense: Firewalls and Tunnels	Detecting and Preventing Intrusions
Week 5	Securing Wireless Networks	Securing Wireless Networks

100 Grading Breakdown

Component	Weight
Project	25%
Final Exam	75%

Policy:

- Passing the final exam is mandatory for the group assignment grade to count toward the final grade.

Collaboration Policy

Academic Integrity

- Submit original work only.
- Discussion with peers is encouraged!

Consequences:

Plagiarism or cheating will result in a failing grade and potential reporting to the university.

Conduct Cybersecurity Exercises ONLY in Lab Environment

- All practical exercises related to cybersecurity **must** be performed exclusively within the lab environment provided by this course.
- Engaging in activities such as:
- Penetration testing
- Network scanning
- Exploiting vulnerabilities

Outside the lab environment is strictly prohibited.

Legal and Ethical Implications

Performing unauthorized cybersecurity activities can:

- **Violate laws** at the local, national, and international levels.
- Lead to **serious legal consequences**, including:
- Fines
- Imprisonment!

What is expected from you?

Category	Number	Time Each	Total Time
Class Time			
Lectures	11	2	22
Lab/Tutorial	6	2	12
Revision class	1	2	2
Total in Class Time			36
Outside Class Time			
Practice exams	1	2	2
Going through lecture slides/notes	11	2	22
Revision			29
Project Work	1	22	22
Total Outside Class Time			75
Total Time			111

Grading Scheme

Grade	Range
10	> 95% - <= 100%
9	> 85% - < 95%
8	> 75% - < 85%
7	> 65% - < 75%
6	> 55% – < 65%
F	<55%

**You have to pass
the exam to
get the grades
for the project!**

**You need >5.5 in your exam (more than 55
% in the written exam)**

Reminder

Ethical Standards in Cybersecurity

- The skills you learn in this course are for **lawful and protective purposes only**.
- Misusing cybersecurity knowledge is a **serious offense** with long-lasting consequences.

Let's focus on learning responsibly! 🙌